DAST: INTEGRAÇÃO DO OWASP ZAP COM O GITHUB ACTIONS

INTRODUÇÃO

O OWASP ZAP (Zed Attack Proxy) é uma ferramenta DAST amplamente conhecida. O DAST atua na fase de Teste e busca encontrar vulnerabilidades como Cross-Site Scripting (XSS), SQL Injection, configurações de segurança incorretas etc., na aplicação em execução.

Neste laboratório será apresentado um fluxo de trabalho no GitHub (GitHub Actions) que, automaticamente, aciona o OWASP ZAP para escanear um site de teste toda vez que uma alteração no repositório for realizada.

IMPORTANTE: Atente-se que as interfaces podem alterar, versões de software, entre outros. Em caso de falhas, verifique o processo semelhante.

1. Criação da Conta no GitHub

(Se você já concluiu este procedimento nos laboratórios anteriores, por favor, **prossiga para a seção** 2).

1. Acesse https://github.com/.
2. Clique em **"Sign up"** (Inscrever-se) e siga as instruções para criar sua conta. Preferencialmente, você pode usar SSO com sua conta do GMail.
3. Verifique seu e-mail.

2. Criando o Repositório de Acionamento e Permissões

Neste laboratório, não haverá um repositório referente à código, mas um repositório no GitHub que irá conter **um arquivo de automação (o workflow)**. Portanto:

1. Na sua página inicial do GitHub, clique no botão **"+"** (canto superior direito) e selecione **"New repository"**.
2. **Nome do Repositório:** zap-dast-integration
3. **Descrição:** "Repositório para testar a integração do OWASP ZAP com GitHub Actions."
4. **Visibilidade:** Selecione **"Public"** (Público). **IMPORTANTE**: Este ponto é crítico para ser possível utilizar o GitHub Actions sem custos.
5. **Importante:** Marque a caixa **"Add a README file"**. Isso facilita o clone e a edição.
6. Clique em **"Create repository"**.
7. **IMPORTANTE**: No repositório recém-criado, selecione a guia **Settings**, no painel esquerdo, no menu **Actions**, em **General**, no final da página, em **Worflow permissions**, marque a opção **Read and write permissions**, e clique em **Save**.

3. Definindo a URL de Teste

O WASP ZAP requer uma URL de uma aplicação em execução para realizar os testes de segurança do DAST.

IMPORTANTE: Nunca realize este processo em sites da Internet sem permissão explícita.

Para testes deste laboratório, será utilizado o projeto oficial de testes da OWASP, chamado **OWASP Juice Shop**. Ele é um site intencionalmente vulnerável, feito para esse tipo de teste.

A URL alvo para os testes deste laboratório será: http://testphp.vulnweb.com/. Você pode testar também com o alvo https://juice-shop.herokuapp.com.

4. Configurando o Workflow do GitHub Actions para o ZAP

Nesta seção, será configurado o GitHub para que toda vez que houver atualização no repositório, ele iniciará uma máquina virtual (ou contêiner), instalará o OWASP ZAP e irá executá-lo para escanear a URL do Juice Shop.

Será utilizado uma "Action" pronta do Marketplace, mantida pela própria equipe do OWASP ZAP. Portanto:

1. Vá até o seu novo repositório zap-dast-integration.
2. Clique na aba **"Actions"**.
3. O GitHub pode sugerir alguns workflows. Clique no link **"set up a workflow yourself"** (fica localizado logo abaixo do título “Get started with GitHub Actions”). Clique em **"set up a workflow yourself"**.
4. O GitHub abrirá um editor para um novo arquivo.
5. Nome do arquivo: altere o nome na barra superior para zap-baseline-scan.yml:

   .github/workflows/zap-baseline-scan.yml
6. **Conteúdo do arquivo:** se houver, apague todo o conteúdo padrão e cole o código abaixo. Leia os comentários para compreender cada linha. O conteúdo deste arquivo também estará disponível no Canvas. Abaixo, o conteúdo:

```
# Nome do fluxo de trabalho: ZAP SCAN Basic

name: ZAP SCAN Basic


on:

# Gatilho manual (perfeito para testes)

workflow_dispatch:
```

```
jobs:

zap_full_scan:

name: Run ZAP Basic Scan

runs-on: ubuntu-latest

# Definição de permissões necessárias

permissions:

contents: write

pull-requests: write

issues: write

steps:

# Passo 1: Checkout (necessário)

- name: Checkout repository

uses: actions/checkout@v3

# Passo 2: Rodar o ZAP Basic Scan

- name: ZAP Basic Scan

uses: zaproxy/action-baseline@v0.14.0

with:

# Alvo de teste

target: 'http://testphp.vulnweb.com/'

- name: Upload ZAP Report

uses: actions/upload-artifact@v4 # Use the latest version

with:
```

```
name: zap-html-report

path: report_html.html
```

7. Clique no botão verde **"Commit changes..."** (Confirmar alterações), no canto superior direito.
8. Deixe a opção padrão ("Commit directly to the main branch") e clique em **"Commit changes"**.

5. Executando o Scan e Analisando os Resultados

Quando foi realizado o "commit" dos arquivos no Passos 4, o workflow foi acionado automaticamente!

1. Clique na aba **"Actions"** do seu repositório.
2. Você verá seu workflow **"ZAP SCAN Basic"** em andamento (ícone amarelo).
3. O VulnWeb Test (Acunetix) é um site complexo, então o scan pode levar de **5 a 15 minutos**.
4. Clique no nome do workflow para acompanhar o progresso.

Relatório (Artefato)

Quando o workflow terminar:

1. Clique no workflow que acabou de rodar.
2. Role para baixo até a seção **"Artifacts"** (Artefatos), na seção "**Upload Zap Report**", na última linha (Artifact download URL:), você verá o **"zap-baseline-report"**. Clique nele para baixar o arquivo .zip.
3. Extraia o arquivo zip e abra o arquivo zap-report.html no seu navegador. Você verá um relatório com todas as vulnerabilidades que o OWASP ZAP encontrou.

Questões Importantes

- Fique atento à diretiva **uses: actions/checkout@v3**, quanto à versão, que pode ficar obsoleto ou não disponível, e impactar na execução da Action. Você deverá verificar qual a versão funcional.
- Fique atento à diretiva **uses: zaproxy/action-baseline@v0.14.0**, quanto à versão, que pode ficar obsoleto ou não disponível, e impactar na execução da Action. Você deverá verificar qual a versão funcional.
- Fique atento à diretiva **uses: actions/upload-artifact@v4**, quanto à versão, que pode ficar obsoleto ou não disponível, e impactar na execução da Action. Você deverá verificar qual a versão funcional.

- Para realizar um Full Scan, altere o **uses: zaproxy/action-baseline@v0.14.0**, para **uses: zaproxy/action-full-scan@v0.13.0**. Você poderá gerar um novo scan a partir do menu Actions. **Você observará que haverão muitas outras vulnerabilidades**.
- A última linha do arquivo YAML da Action, **path: report_html.html**, é dependente do tipo de arquivo que a imagem do OWASP ZAP gera, portanto, em casos de erro, deve-se observar quais os tipos de saída que foram geradas na trigger Zap Basic Scan, com o argumento -r.
- Realize testes também sobre a URL https://juice-shop.herokuapp.com, bastando alterar a diretiva **target**.

Conclusão

Neste laboratório foi configurado um pipeline de DAST automatizado com o OWASP ZAP.

O que foi realizado:

1. Criação de um repositório no GitHub.
2. Configuração de um workflow de GitHub Actions para rodar o OWASP ZAP.
3. Definiu um alvo de teste (VulnWeb Test (Acunetix) ou OWASP Juice Shop).
4. Executou um scan DAST (Baseline).
5. Download dos artefatos (Relatório HTML) para análise.